

UST-2026-09-27-21

Operational readiness antes de GA: inventario COMPLETO de cuentas y secretos (medido: ~40 en 13 sistemas), una a una — dónde vive, quién la custodia, en qué estado está, cómo se rota sin que ningún valor pase por el chat y cómo se comprueba que todo sigue funcionando después

PROPUESTA (27-sep 13:4x, tras UST-19 A desplegada y UST-20 entregada). DECISIÓN YA TOMADA (D0, Juanjo 27-sep): nada se rota hasta la semana previa a producción (noviembre). Este documento es el inventario y el plan; hasta noviembre solo se VERIFICA dónde vive cada cosa y se recogen evidencias. El inventario está MEDIDO en el repo (grep de `Deno.env.get` en las 13 Edge Functions, `vault.create\_secret` en backend-sql, `secrets.\*` en los workflows de GitHub, `env.\*` en las Pages Functions, nombres de variables de `secrets/edge-functions.env`, ficheros de `secrets/`), no recordado.

1 · El pedido, literal

Juanjo, 27-sep-2026, tras guardar en secrets/ la contraseña y los recovery codes de Cloudflare y pedir que la rotación entrara en la regla de cambios pre-producción:

«metelo en la regla de cambios a realizar antes de ir a producccion» (→ CLAUDE.md «Deuda anotada (27-sep) — ROTAR ANTES DE PRODUCCIÓN (GA)» + item GA en el tablero).

«operational readinesss checklist, con todas las cuentas y contraseñas a rotar y verificar una por una».

«No, no vamos a rotar nada hasta que vayamos a produccion en Noviembre» (27-sep 13:4x, al ver el plan) → D0, decidido.

Lectura: no un recordatorio de «cambiar contraseñas», sino el INVENTARIO completo (lo que el mapa de secrets/README.md no tenía: hoy lista 13 entradas y la realidad medida son ~40), con una fila por credencial que diga dónde vive, quién más la tiene, si está expuesta o caduca, qué se hace exactamente con ella en la semana previa a GA y cómo se comprueba que nada se rompió. Y una regla de método: el inventario se mide en el código (qué variables leen las funciones, qué secretos usan los workflows, qué hay en el Vault), no se recuerda.

2 · Inventario medido el 27-sep (repo + secrets/ + workflows), sin valores: qué hay y dónde vive

Qué	Medido
Cuentas de persona (identidades)	13: GitHub `githubjuanjose` (dueño de los 3 repos, identidad de Cloudflare por «Sign in with GitHub») · Cloudflare `juanjose.cebrian@outlook.com` (dominio, Pages x3, Access, Turnstile, R2, WAF) · Outlook (buzón de recuperación de Cloudflare y GitHub) · Apple ID `juanjosecebrian@icloud.com` (Developer Program, ASC, TestFlight; Team G9W35DBZW9) · Google del dueño de Play «NutriSync Engineering» (5111219179202532774) + Google Cloud (OAuth de Sign-in, Firebase push/Crashlytics) · Supabase (Juanjo; la ORG es de Pilar, pgonzalez.ieu2023@...) · Expo `expojuanjo` · IONOS (contrato de Pilar; 8 buzones) · Notion (Pilar; Juanjo `juanjo.skg@gmail.com`) · Figma (fichero de Lucía; token de Juanjo) · OpenAI (org de Juanjo) · USDA FDC (alta con el gmail) · los 4 Gmail de las founders (a ellos llega el PIN de Cloudflare Access = segundo factor del hub).

Qué	Medido
secrets/ en el Mac (13 ficheros; fuera de git; copia cifrada en R2 por backup-auto cada 4 h — `secrets/.copia` sellada hoy)	`edge-functions.env` (10 variables: ASC_APP_ID · ASC_ISSUER_ID · ASC_KEY_ID · FIGMA_TOKEN ×3 líneas · NS_CRON_SECRET · NS_GATEWAY_SECRET · OPENAI_API_KEY · QA_GRANJA_PASS · TURNSTILE_SECRET · USDA_FDC_API_KEY) · `edge-functions.envecho` (fichero ACCIDENTAL con FIGMA_TOKEN: nació de un `>>` mal escrito) · `AuthKey_BH9UP35Y4X.p8` · `db-url.txt` (rol postgres) · `ns-backup-token.txt` (64 bytes) · `google-oauth-client.json` · `nutrisync-push-firebase-adminsdk-...json` (service account de Firebase) · `BUZONES-IONOS.md` (8 buzones con sus contraseñas) · `CLOUDFLARE-cuenta.md` + `cloudflare-recovery-codes-2026-09-27.txt` (EXPUESTOS) · `firma-juanjo.png` (imagen de firma: sensible, no credencial) · `WIFI-ROUTER.md` (personal, fuera de alcance) · `README.md` (el mapa: 13 filas, incompleto).
Supabase · Vault (4 secretos)	`NS_CRON_SECRET` (la puerta real de los crons) · `NS_BACKUP_TOKEN` (backup-auto informa a la base) · `NS_OPS_PIN` (tercera capa de ops evidencia) · `ns_feedback_token` (trigger de feedback → Edge). Además `service_role` (solo Vault/Edge, auto-inyectada) y la `anon key` (pública por diseño, RLS manda).
Supabase · secretos de Edge Functions (13 funciones; medido con grep de `Deno.env.get`)	analyse-meal: NS_CRON_SECRET · OPENAI_API_KEY — community-lead: SMTP_HOST/USER/PASS — feedback-email: NS_FEEDBACK_TOKEN · SMTP_* — food-lookup: NS_CRON_SECRET · USDA_API_KEY · USDA_FDC_API_KEY (la MISMA clave con dos nombres) — founder-reminders · pilot-outreach · ticket-escalation: NS_CRON_SECRET · SMTP_* — notify-dispatch · pase-directo: solo las auto-inyectadas — qa-granja: NS_CRON_SECRET · QA_GRANJA_PASS — store-stats: ASC_APP_ID/BUNDLE_ID/ISSUER_ID/KEY_ID/PRIVATE_KEY · NS_CRON_SECRET — waitlist-join: NS_GATEWAY_SECRET · TURNSTILE_SECRET — web-stats: **CF_API_TOKEN · CF_ZONE_ID** (un token de la API de Cloudflare vive en Supabase y NO estaba en el mapa). Y OJÓ: el Deploy Edge sube `edge-functions.env` ENTERO (`--env-file`), así que FIGMA_TOKEN y todo lo del fichero viven también en el servidor aunque ninguna función los use.
Cloudflare · Pages (secretos de proyecto)	`NS_GATEWAY` en `nutrisync-collective` y `nutrisync-web2` (= NS_GATEWAY_SECRET de la Edge; la Pages Function `/api/waitlist` lo exige). Cambiar un secreto de Pages exige un despliegue nuevo para que la Function lo lea. Tokens de API de la cuenta (My Profile → API Tokens): el de GitHub Actions (Pages deploy), el de web-stats (Edge), el de R2 (rclone), el OAuth de wrangler del Mac — inventario exacto pendiente de leerlo en el panel (F-A2).
GitHub · Actions (secretos de repositorio, medido en los workflows)	`nutrisync-web` (webdeploy): `CLOUDFLARE_API_TOKEN` + `CLOUDFLARE_ACCOUNT_ID` (deploy-web.yml: push = deploy). `nutrisync-app` (appdev): `EXPO_TOKEN` en `eas-update.yml` — **un workflow que publica `eas update --branch production` en CADA push a main** (plantilla del arranque, PIPELINE.md), fuera de la doctrina OTA (el .command con los runtimes): si el secreto está puesto, cada push publica una OTA al runtime de app.json con el mensaje del commit, sin backup-estado ni jest. No consta en CLAUDE.md. Se MIDE en Actions (F-C16) antes de decidir (D8).
EAS / Expo (custodia de firma y envíos)	Clave ASC de envíos `6GXZ67N7VZ` («[Expo] EAS Submit», solo en EAS) · certificado + perfil iOS (caducan 29-jul-2027) · keystore Android (generado 5-ago; SOLO existe en EAS: «no hay fichero local que perder» = tampoco hay copia fuera del proveedor) · credenciales FCM V1 para push Android (service account de Firebase) · `EXPO_TOKEN` (ver arriba).
Mac de Juanjo · llavero y configs (se re-crean con login; NO van al gestor)	git por HTTPS en los 3 repos (credencial de GitHub en el llavero; la usa también backup-auto cada 4 h) · `npx supabase login` (access token) · `eas login` · `wrangler login` (OAuth; 4 .command lo usan) · `~/config/rclone/rclone.conf` (600: token de R2 + contraseña de cifrado OFUSCADA, la de verdad solo en el gestor) · `r2-bucket`.
Gestor compartido (regla 11-ago: ninguna llave en una sola cabeza)	CONTINUIDAD-Llaves-Compartidas.md define las fichas 1-2 (R2 + contraseña de cifrado) y las opciones (Contraseñas de Apple, grupo «NutriSync» / Bitwarden). Estado real (a confirmar con Pilar): #28-#31 hechos, simulacro #32 pendiente. TODO valor nuevo de esta UST nace en el gestor. Pilar duplica en su bóveda personal.
Estado de exposición (lo que obliga a rotar en noviembre, D0)	EXPUESTAS: contraseña de Cloudflare + 8 recovery codes (chat, 27-sep) · contraseña de la BASE (chat + historial de shell, 15-ago) · FIGMA_TOKEN (listado en pantalla, 26-sep; y el fichero `envecho`). DÉBIL: contraseña de cifrado sin sal. CADUCAN: cert/perfil iOS 29-jul-2027 · membresía anual de Apple Developer (fecha a leer en developer.apple.com → Membership) · el «secret key» JWT de Sign in with Apple en Supabase Auth, si está configurado, caduca cada 6 meses (F-C19). El resto: sin exposición conocida → VERIFICAR, y rotar por higiene solo lo que D6 diga.

Analogía: Rotar credenciales es un rolling update de Secrets en Kubernetes: primero `kubectrl get secrets` en TODOS los namespaces (el inventario: aquí faltaban CF_API_TOKEN, el envecho, EXPO_TOKEN...), luego por cada Secret creas la versión nueva, la montas en los pods que la leen (Edge, Pages, Actions, el Mac), compruebas con una petición real que los pods nuevos responden, y solo entonces borras la vieja. Las llaves maestras (service_role) no se rotan por costumbre sino con motivo, porque cambiarlas reinicia todo el clúster a la vez. Y el gestor compartido es el etcd cifrado: si solo un nodo lo tiene, no hay clúster.

3 · Una a una: bloque 0 (preparación) · A (identidades de persona) · B (expuestas → rotar en noviembre) · C (secretos de máquina: verificar dónde viven; rotar solo lo que D6 marque)

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
0.1 · Gestor compartido operativo (AHORA, no es rotar)	HOY: fichas 1-2 (R2 + cifrado) en el gestor según CONTINUIDAD; grupo/coste a confirmar (#28). QUÉ: confirmar que Pilar Y Lucía ven el grupo «NutriSync» (Contraseñas de Apple) o la organización de Bitwarden (D3); que Pilar ha duplicado las fichas 1-2 en su bóveda; crear las fichas VACÍAS de esta lista (una por fila A/B/C con «dónde vive» y «cómo se recupera») para que en noviembre solo haya que rellenar el valor. Es el destino de todo lo nuevo: sin gestor no se rota nada.	Las tres abren una ficha de prueba «NutriSync · prueba 27-sep» desde su móvil; Pilar enseña la copia en su bóveda; simulacro #32 (Pilar recupera un fichero de R2 sola) hecho y sellado en ops_evidencia.
0.2 · Baseline y copia ANTES de rotar (noviembre, día 0)	`tools/baseline.sh` (repos · sellos · OTA ids · copias) + `node tools/backup-estado.mjs` en verde + `rclone sync` de `secrets/` a R2 (backup-auto ya lo hace cada 4 h; se fuerza una pasada) + `secrets/README.md` reescrito con las ~40 filas de este documento (hoy 13). Cada fila que se rote guarda el valor VIEJO en el gestor con sufijo «(vieja, borrar tras verificación)» hasta que la nueva esté verificada.	`archive/logs/baseline-<fecha>.txt` existe; backup-estado sin Δ; `secrets/.copia` sellada ese día; README con ~40 filas (web-tests no lo mira: se comprueba a ojo).
A1 · GitHub `githubjuanjose` — identidad de Cloudflare («Sign in with GitHub»), dueño de los 3 repos y de los secretos de Actions	HOY: 2FA a confirmar; recovery codes ¿en el gestor?; PATs y OAuth apps sin inventariar. QUÉ (verificar ahora, rotar nada): github.com/settings/security → 2FA «Enabled» con app (si no, activarla); «Recovery codes» → descargar → gestor (fichero, no chat); Settings → Developer settings → Personal access tokens: cada token con nombre reconocible (el del llavero del Mac, el de backup-auto si es distinto) y fecha de caducidad; los desconocidos se borran; Settings → Applications → Authorized OAuth Apps: deben estar Cloudflare, Expo, Claude/Notion si aplica — nada más; Pilar como colaboradora (o la org NutriSync) con 2FA obligatoria (continuidad: si GitHub cae, cae Cloudflare y el deploy).	Captura de «Two-factor authentication: Enabled» a ops_evidencia; `git push` de prueba desde el Mac funciona; Action deploy-web.yml verde en el siguiente Deploy Web; Pilar acepta la invitación y ve los 3 repos.
A2 · Cloudflare `juanjose.cebrian@outlook.com` — EXPUESTA (contraseña + 8 recovery codes en el chat, 27-sep) → ROTAR en noviembre; 2FA puede activarse antes (UST-20 F12, con la contraseña actual: activar no es rotar)	HOY: login por GitHub + contraseña propia (la pide el 2FA); valores en `secrets/CLOUDFLARE-cuenta.md` y `cloudflare-recovery-codes-2026-09-27.txt`. QUÉ (noviembre): My Profile → Authentication → Password → «Change Password» (la actual está en secrets; la nueva la genera el gestor) → 2FA Mobile App si aún no está → «Regenerate backup codes» (los 8 del 27-sep quedan inválidos) → el fichero nuevo descargado de Cloudflare SUSTITUYE a `cloudflare-recovery-codes-2026-09-27.txt` (mismo patrón: el fichero es la verdad; la tabla del .md solo dice «código n · usado/fecha») → fichas al gestor; Manage Account → Members → Pilar «Administrator» + «Enforce 2FA»; My Profile → API Tokens: inventario con nombre, permiso mínimo y último uso (Pages deploy · web-stats · R2 · wrangler); los que nadie reconozca, «Delete»; los que se conservan se «Roll» solo si D6 lo marca (cada uno tiene su fila C).	Login con la contraseña nueva + TOTP; Security → Insights ya no lista «Users without MFA»; Pilar entra con su cuenta; `node tools/smoke-prod.mjs` PRODUCCIÓN SANA; `secrets/CLOUDFLARE-cuenta.md` sin ningún valor del 27-sep.
A3 · Outlook `juanjose.cebrian@outlook.com` — es la puerta trasera de Cloudflare (reset de contraseña por correo) y el buzón de facturas de GitHub	HOY: sin inventariar. QUÉ (verificar ahora): account.microsoft.com → Security → 2FA activa con app o llave; métodos de recuperación (móvil/correo alternativo) al día; sesiones/dispositivos: cerrar los desconocidos; contraseña al gestor (si no hay 2FA, ROTAR en noviembre junto a A2, porque quien entre ahí resetea Cloudflare).	Captura «Two-step verification: On» a ops_evidencia; un «Forgot your password?» de Cloudflare llega a ese buzón (prueba sin completar el reset).
A4 · Apple ID `juanjosecebrian@icloud.com` — Developer Program (Team G9W35DBZW9), App Store Connect, TestFlight, firma en EAS	HOY: 2FA obligatoria en Apple (ok por construcción); membresía anual con fecha desconocida en el tablero; Lucía con invitación a Users and Access pendiente. QUÉ (verificar ahora): developer.apple.com → Membership: fecha de renovación → a la base (`caduca_el`) y renovación automática con tarjeta vigente; Users and Access → Pilar «Admin» (continuidad: si Juanjo falta, alguien tiene que poder enviar builds y responder a App Review) y Lucía acepta; Integrations → las DOS claves API (`6GXZ67N7VZ` envíos · `BH9UP35Y4X` store-stats) identificadas por Key ID, ninguna más; dispositivos de confianza revisados.	Fecha de membresía en la tabla; Pilar entra en ASC; solo 2 claves API listadas; `eas credentials` (iOS) muestra cert y perfil hasta 29-jul-2027.

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
A5 · Google — dueño de Play Console «NutriSync Engineering» (5111219179202532774), Google Cloud (OAuth de Sign-in + Firebase push/Crashlytics), USDA alta	HOY: qué gmail es el dueño de Play NO está escrito en ningún sitio (medirlo: Play Console → Account details). QUÉ (verificar ahora): esa cuenta con 2FA (app o llave), backup codes al gestor; Play → Users and permissions → Pilar «Admin (all permissions)»; Google Cloud → IAM del proyecto de Firebase/OAuth → Pilar Owner; Google Cloud → Credentials → inventario: OAuth client (Sign in with Google), API keys de Firebase (restringidas por paquete/bundle), service accounts (la del JSON de secrets) — nada desconocido.	Captura de 2FA a ops_evidencia; Pilar entra en Play y en Cloud; inventario de credenciales de Cloud pegado en el doc as-built (solo nombres).
A6 · Supabase — cuenta de Juanjo, ORG de Pilar (owner), proyecto `nebkqncvapelrarru yqb` (EU, Pro)	HOY: Pilar owner ✓; MFA de las cuentas a confirmar; access tokens del CLI sin inventariar. QUÉ (verificar ahora): Account → Security → MFA activa (Juanjo y Pilar); Account → Access Tokens: el del Mac (`supabase login`) y ninguno más; Project → Settings → API: las claves nuevas (`sb_publishable_...` pública · `sb_secret_...`) — la secret NO vive en ningún fichero del Mac ni repo (grep = 0); Auth → Providers: Apple y Google configurados (ver C18/C19); Database → la contraseña del rol postgres (B2).	MFA «Enabled» en ambas cuentas (captura); `npx supabase projects list` desde el Mac funciona; `grep -r sb_secret_repos/ tools/ backend-sql/ secrets/` = 0.
A7 · Expo `expojuanjo` — builds, OTAs, custodia de firma (cert iOS, keystore Android, clave ASC de envíos, FCM)	HOY: 2FA a confirmar; sin segundo miembro. QUÉ (verificar ahora): expo.dev → Account settings → 2FA con app, recovery codes al gestor; Access tokens: inventario (¿existe el `EXPO_TOKEN` de Actions? → C16); Members: Pilar (Admin) — si Expo se pierde, se pierde el keystore (D7).	2FA activa (captura); `eas whoami` desde el Mac; Pilar entra en expo.dev; `eas credentials` (Android) lista el keystore.
A8 · IONOS — contrato de Pilar: correo del dominio (8 buzones) y quizá el registro del dominio	HOY: contraseñas de los 8 buzones en `secrets/BUZONES-IONOS.md`; feedback@ es la que usa SMTP_PASS (C6). QUÉ (verificar ahora): cuenta IONOS con 2FA (Pilar); ¿dónde está registrado `nutrisynccollective.com`? (IONOS o Cloudflare Registrar: leerlo en el panel; renovación automática con tarjeta vigente; DNS en Cloudflare ✓); los 8 buzones al gestor compartido (el fichero se queda como copia cifrada en R2); alias `founders@` reparte a 7 buzones (digest).	Registro y fecha de renovación en la tabla; login IONOS de Pilar con 2FA; un correo real de feedback@ con dkim=pass · spf=pass (cabecera en Gmail).
A9 · Notion (workspace de Pilar; Juanjo `juanjo.skg@gmail.com`; conector de Claude autorizado)	HOY: sin bloques (plan Free agotado desde el 8-sep); la verdad para las founders es el hub. QUÉ (verificar): 2FA en las cuentas de Notion; Settings → Connections: solo el conector conocido; plan (Plus) cuando Pilar decida.	2FA activa; lista de conexiones pegada (nombres).
A10 · Figma (fichero «NutriSync — WebV2» de Lucía; token personal de Juanjo)	HOY: token EXPUESTO (26-sep) → B3. QUÉ (verificar): 2FA de Lucía y Juanjo en Figma; Settings → Security → Personal access tokens: uno solo, con nombre y caducidad.	2FA activa; un único token listado (tras B3, el nuevo).
A11 · OpenAI (org de Juanjo; «NutriSync Vision», límite 20 \$/mes)	HOY: clave en env + Edge (analyse-meal). QUÉ (verificar): 2FA de la cuenta; API keys: una sola («NutriSync Vision»), límite de gasto vigente; rotación por higiene en noviembre si D6 lo marca (C12).	2FA activa; Usage sin picos; `Deploy Edge analyse-meal.command` veredicto en vivo tras cualquier cambio.
A12 · Los 4 Gmail de las founders (Juanjo · Pilar · Lucía · Mapi) — a ellos llega el PIN de Cloudflare Access: SON el segundo factor del hub (UST-17)	HOY: no consta que se haya comprobado. QUÉ (verificar ahora, cada una la suya): myaccount.google.com → Security → «2-Step Verification: On» (app o llave; no solo SMS); métodos de recuperación al día; «Your devices» sin desconocidos. Sin esto, «un candado» tiene la cerradura en un buzón sin llave.	Cada founder manda captura de «2-Step Verification: On» → ops_evidencia (4/4).
A13 · Cuentas del hub (Supabase Auth · tabla `admins`: 4 emails) · cuenta demo de App Review `review@nutrisynccollective.com` · las 12 QA de la granja	HOY: contraseñas del hub de Pilar y Lucía (una vez por dispositivo); demo de review@ en el gestor de Juanjo; granja con QA GRANJA_PASS (C17). QUÉ: si alguna contraseña del hub viajó por WhatsApp/chat → recovery (`POST /auth/v1/recover`) en noviembre; review@ al gestor compartido (Apple la tiene en «App Review Information»: si se cambia, se actualiza AHÍ en el mismo acto o la review falla); las cuentas del hub NO tienen TOTP obligatorio (un candado) — refuerzo opcional en mfa.html.	Las 3 entran al hub sin reto extra (Access PIN mensual + contraseña por dispositivo); App Review Information con la demo vigente; `admin-tests` verde.

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
B1 · Contraseña de Cloudflare + recovery codes — EXPUESTA (chat 27-sep)	→ A2 (noviembre). Hasta entonces: los valores viven SOLO en `secrets/` (fuera de git; cifrados en R2). Nadie los vuelve a pegar en ningún sitio.	→ A2.
B2 · Contraseña de la BASE (rol postgres; `secrets/db-url.txt`) — EXPUESTA (chat + historial de shell, 15-ago)	HOY: único consumidor = `tools/backup-auto.sh` (pg_dump cada 4 h → R2 cifrado). Es el rol postgres: salta la RLS. QUÉ (noviembre): Supabase → Project Settings → Database → «Reset database password» (Supabase la genera: no se teclea) → gestor → re-crear `secrets/db-url.txt` con la cadena nueva (se escribe desde el gestor al fichero, sin pasar por el chat; formato: la cadena «Direct connection» o el pooler que ya usa) → `grep -rn 'db-url' tools/` para confirmar que nada más la lee → esperar la siguiente corrida de las 4 h.	`pg_dump "\$(cat secrets/db-url.txt)" --schema-only   head -c 200` responde desde el Mac; la corrida de backup-auto informa OK en la base (NS_BACKUP_TOKEN → hub backup-estado); `~/zsh_history` sin la cadena vieja (se borra la línea) y el chat viejo no importa: la contraseña ya no vale.
B3 · FIGMA_TOKEN — EXPUESTO (listado 26-sep) + fichero accidental `secrets/edge-functions.envecho`	HOY: 3 líneas `FIGMA_TOKEN=` en `edge-functions.env` (rotaciones anteriores con `echo >>` dejaron las viejas) + el `envecho`; el Deploy Edge lo sube al servidor sin que ninguna función lo use. QUÉ (noviembre, junto a D4): Figma → Settings → Security → revocar TODOS los tokens → crear uno («NutriSync tools», con caducidad) → escribirlo UNA vez en `secrets/tools.env` (fichero nuevo para lo que usa el Mac, D4) → borrar las 3 líneas de `edge-functions.env` y el `envecho` → `npx supabase secrets unset FIGMA_TOKEN` → las herramientas (`tools/figma-export.mjs`, `figma-children.mjs`, `figma-bounds.mjs`) leen de `tools.env`.	`node tools/figma-children.mjs <frame>` responde 200; `grep -c FIGMA_TOKEN secrets/edge-functions.env` = 0; `envecho` no existe; `npx supabase secrets list` (solo nombres) sin FIGMA_TOKEN.
B4 · Contraseña de cifrado de rclone (R2) — DÉBIL: sin sal (`password2` vacío); protege `feedback/`, `inputs/`, `secrets/` y el volcado de la base (datos de salud)	HOY: la de verdad solo en el gestor; en el Mac ofuscada en rclone.conf; 5,73 GB cifrados con ella. QUÉ (noviembre, tarea grande — D5): `rclone config` → remoto crypt NUEVO `r2salud` (contraseña nueva + `password2` = sal, ambas generadas por el gestor; `filename_encryption=standard`, `directory_name_encryption=true`) sobre un prefijo nuevo del bucket → `rclone sync` de lo sensible (secrets · feedback · inputs · basedatos) → `rclone check` → backup-auto apunta al remoto nuevo → 30 días de DOBLE copia → borrar el prefijo viejo. Fichas 1-2 del gestor REESCRITAS con la forma exacta del remoto nuevo (con la forma equivocada rclone devuelve basura y parece «contraseña mal»); Pilar duplica.	`rclone check r2salud: <origen>` sin diferencias; restauración de UN fichero desde otro Mac/usuario con solo las fichas del gestor (simulacro #32, esta vez con el remoto nuevo); backup-auto informa OK con el remoto nuevo durante 30 días antes de borrar el viejo.
C1 · service_role de Supabase (auto-inyectada en las 13 Edge; ninguna copia en ficheros)	HOY: sin exposición conocida. QUÉ (verificar, NO rotar por costumbre — D6): `grep -rn 'service_role sb_secret_ eyJhbGciOi' repos/ tools/ backend-sql/ secrets/ Hub-*/` = 0 apariciones de un valor (los nombres sí aparecen); si alguna vez apareciera un valor → rotación en Supabase (API keys → «Roll» de la secret key; las Edge la reciben solas) y redeploy de nada.	El grep del as-built = 0 valores; smoke sano; crons verdes 24 h.
C2 · anon key (`sb_publishable_...`, pública por diseño)	No se rota: la seguridad es la RLS + las policies. QUÉ (verificar): `admin-tests` y smoke (POST anónimo a waitlist = 401; RPCs admin sin sesión = 401/400).	smoke PRODUCCIÓN SANA con los checks de waitlist; admin-tests 45/45.
C3 · NS_CRON_SECRET (Vault + Edge secrets; lo exigen 10 funciones; lo mandan los crons de pg_net)	HOY: creado 4-ago, nunca expuesto. QUÉ (noviembre, por higiene si D6 = sí): a las :35 (fuera de los minutos de los crons :05/:15/:20/:40) → `openssl rand -hex 32 > secrets/ns-cron-secret.new` → SQL `select vault.update_secret(<id>, pg_read_file...)` NO: el Vault se actualiza desde el editor con el valor pegado desde el fichero (portapapeles, un uso) → `npx supabase secrets set --env-file secrets/edge-functions.env` (con la línea nueva) → borrar el `.new`. Ventana de minutos en la que un cron daría 401: por eso la hora.	curl de sonda con `x-ns-cron` nuevo → 200 (founder-reminders dry, qa-granja salud); `cron.job_run_details` de la hora siguiente sin fallos; el valor viejo → 401.
C4 · NS_GATEWAY_SECRET (Edge waitlist-join) = NS_GATEWAY (Pages ×2)	HOY: 26-sep, nunca expuesto. QUÉ (verificar; rotar solo si D6): valor nuevo → Pages `nutrisync-collective` y `nutrisync-web2` (Settings → Variables and Secrets) → `supabase secrets set` → Deploy Web2 + Deploy Web (po) para que las Functions lo lean → smoke.	smoke: `/api/waitlist` honeypot → 200, sin gateway → 403 (curl directo a la Edge con el valor viejo → 403).
C5 · TURNSTILE_SECRET (Edge) + site key pública (`repos/web2/src/turnstile.json`)	HOY: 26-sep. QUÉ (verificar): Cloudflare → Turnstile → widget «NutriSync web»; dominios = solo los nuestros, modo interaction-only; rotación (si D6) = «Rotate secret key» → env + secrets set → Deploy Edge waitlist-join.	Alta real por la web → `waitlist_ritmo.verificado = true` (sonda 2026-09-27-sonda-ust19-a-verificado.sql); veredicto del Deploy Edge 5/5.

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
C6 · SMTP_HOST / SMTP_USER / SMTP_PASS (Edge x5: community-lead, feedback-email, founder-reminders, pilot-outreach, ticket-escalation) = contraseña del buzón feedback@ (IONOS)	HOY: buzón de Pilar; contraseña en BUZONES-IONOS.md. QUÉ (noviembre, por higiene si D6): IONOS → buzón feedback@ → contraseña nueva (generada) → gestor + BUZONES-IONOS.md → `supabase secrets set --env-file` (línea SMTP_PASS en el fichero de Edge) — los secretos de Edge se leen en la siguiente invocación, sin redeploy — → UN envío real (regla r15: una función de correo no está viva hasta ver un correo).	Correo real de founder-reminders (digest 07:15) o un lead de prueba con `ack:sent`; cabecera dkim=pass; ningún 535 en los logs de las 5 funciones.
C7 · ns_feedback_token (Vault) = NS_FEEDBACK_TOKEN (Edge feedback-email) — el trigger de feedback llama a la Edge con él	HOY: sin exposición. QUÉ (verificar; rotar si D6): valor nuevo en los DOS lados en el mismo acto (Vault + secrets set); prueba con un feedback desde la app.	Feedback de prueba → correo a founders@ llega; `feedback_ticket_events` con el evento; sin 401 en los logs de feedback-email.
C8 · NS_BACKUP_TOKEN (Vault) = `secrets/ns-backup-token.txt` — backup-auto informa a la base cada 4 h	HOY: sin exposición. QUÉ (verificar): que la RPC de informe exige el token (sonda: sin token → error); rotación (si D6) = `openssl rand -hex 32 > secrets/ns-backup-token.txt` + Vault en el mismo acto.	Siguiente corrida de backup-auto informa OK (hub backup-estado / daily-ops); con el token viejo → rechazo.
C9 · NS_OPS_PIN (Vault) — tercera capa de ops_evidencia (URLs firmadas)	HOY: PIN corto; ¿se compartió por chat/WhatsApp? Si sí → rotar (noviembre). QUÉ: Vault → nuevo PIN (gestor); el bloqueo tras 5 fallos sigue.	Abrir una evidencia con el PIN nuevo; el viejo → «PIN incorrecto» y cuenta en ops_pin_intentos.
C10 · Clave ASC `BH9UP35Y4X` (store-stats): `.p8` en secrets + ASC_PRIVATE_KEY/KEY_ID/ISSUER_ID en Edge y env	HOY: 4-ago, sin exposición (la del 14-ago fue la copia local RANCIA de la clave anterior, no una fuga). QUÉ (verificar; rotar solo si se compromete): ASC → Integrations → nueva clave App Manager → `.p8` descargado UNA vez a `secrets/` (chmod 600) → env (las 3 variables) → `supabase secrets set --env-file` → curl store-stats 200 → SOLO ENTONCES revocar la vieja, identificada por Key ID (lección 4-ago: las dos claves salen del mismo menú).	curl x-ns-cron a store-stats → snapshot por instalaciones; `store_snapshots` con fila del día siguiente (06:30 UTC).
C11 · Clave ASC `6GXZ67N7VZ` («[Expo] EAS Submit», vive solo en EAS)	HOY: sin exposición. QUÉ (verificar): `eas credentials` → iOS → App Store Connect API Key presente y con ese Key ID; rotación solo si se compromete (nueva en ASC → `eas credentials` → sustituir → revocar la vieja).	`eas submit -p ios --latest` del siguiente build entra sin 401 (o `eas credentials` la lista).
C12 · OPENAI_API_KEY (Edge analyse-meal; env)	HOY: 9-ago; límite 20 \$/mes. QUÉ (noviembre, por higiene si D6): platform.openai.com → nueva clave → env → secrets set → revocar la vieja tras el veredicto.	`Deploy Edge analyse-meal.command` veredicto en vivo (pregunta a la función); Usage en OpenAI sin picos.
C13 · USDA_FDC_API_KEY (+ USDA_API_KEY: la misma clave con dos nombres en food-lookup)	HOY: gratis, 9-ago. QUÉ (verificar; unificar): dejar UN nombre (`USDA_FDC_API_KEY`) en la función y en el env; `secrets unset USDA_API_KEY`.	food-lookup responde con x-ns-cron; una sola variable USDA en `secrets list`.
C14 · CF_API_TOKEN + CF_ZONE_ID (Edge web-stats) — un token de la API de Cloudflare vive en Supabase y NO estaba en el mapa	HOY: permisos y fecha desconocidos. QUÉ (verificar ahora en el panel): Cloudflare → API Tokens → identificarlo por nombre/último uso; permisos MÍNIMOS (Zone · Analytics · Read, una sola zona); si es más amplio → «Roll»/crear uno mínimo (noviembre) → secrets set. Anotarlo en secrets/README.md.	curl x-ns-cron a web-stats → 200 con visitas; el token listado en Cloudflare con «Last used» reciente y permisos de solo lectura.

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
C15 · CLOUDFLARE_API_TOKEN + CLOUDFLARE_ACCOUNT_ID (GitHub Actions, repo `nutrisync-web`: push = deploy)	HOY: sin inventariar en Cloudflare. QUÉ (verificar): token con permiso «Cloudflare Pages · Edit» y nada más; rotación (si D6) = «Roll» en Cloudflare → GitHub → Settings → Secrets and variables → Actions → actualizar → siguiente Deploy Web.	Action «deploy-web» verde en el siguiente po; el token viejo → la Action falla (se prueba solo si se rota).
C16 · EXPO_TOKEN (GitHub Actions, repo `nutrisync-app`: workflow `eas-update.yml` publica `eas update --branch production` en CADA push a main)	HOY: workflow heredado del arranque (PIPELINE.md); contradice la doctrina OTA (el .command: backup-estado + jest + 7 runtimes + mensaje). MEDIR AHORA: GitHub → nutrisync-app → Actions → runs de «EAS Update (OTA)»: si hay runs verdes, ha estado publicando OTAs al runtime de app.json a espaldas del proceso; si fallan (sin secreto), es ruido. QUÉ (D8): retirar el workflow del repo (y del espejo pwaddev) + borrar el secreto en GitHub y el access token en Expo; si Juanjo quisiera CI para OTAs, sería otro workflow con la lista RUNTIMES y las puertas del .command (UST aparte).	Actions sin el workflow; `eas update:list --branch production` sin updates cuyo mensaje sea un commit de git; expo.dev → Access tokens vacío (o solo los reconocidos).
C17 · QA_GRANJA_PASS (Edge qa-granja; contraseña común de las 12 usuarias sintéticas; cron 05:10 UTC)	HOY: 4-sep, sin exposición. QUÉ (verificar; rotar si D6): contraseña nueva (gestor) → admin API cambia la de las 12 (`qa_synthetic_users`) → secrets set en el mismo acto → siguiente corrida 36/36.	`qa_runs` del día siguiente en verde (36/36); la granja sigue fuera de métricas y de Play.
C18 · Google OAuth client (Sign in with Google: `secrets/google-oauth-client.json` + Supabase Auth → Providers → Google)	HOY: la app entra con `signInWithIdToken` (nativo). QUÉ (verificar): que el JSON no ha salido de secrets (no está en repos: grep); Google Cloud → Credentials → el client tiene solo los redirect URIs de Supabase; rotación (si se compromete) = «Reset secret» → repegar en Supabase (desde el gestor).	Login con Google en un iPhone y un Android reales (regla de paridad); `grep -r client_secret repos/` = 0.
C19 · Sign in with Apple (Supabase Auth → Providers → Apple: Services ID / Client IDs + «Secret Key» JWT firmado con un .p8 de Apple, caduca cada 6 meses)	HOY: la app iOS entra con `signInWithIdToken` (expo-apple-authentication; no necesita el JWT); el JWT solo hace falta para web/Android. MEDIR AHORA: si el proveedor lleva «Secret Key», anotar cuándo se generó (caduca_el = +6 meses) y si la PWA/Android lo usan; si no lo usan, dejar constancia y no renovarlo; si lo usan, renovarlo en noviembre (ASC → Keys → Sign in with Apple .p8 → JWT → Supabase).	Login con Apple en iPhone real; si web: en m.nutrisynccollective.com; fecha de caducidad en la tabla con aviso a 30 días (D1).
C20 · Firebase (proyecto de push/Crashlytics): service account `nutrisync-push-firebase-adminsdk-....json` (secrets) → credenciales FCM V1 en EAS; `google-services.json` / `GoogleService-Info.plist` en appdev (identificadores públicos, restringidos por paquete)	HOY: sin exposición conocida. QUÉ (verificar): `eas credentials` → Android → FCM V1 presente; Google Cloud → Service accounts → esa cuenta con UNA clave y rol mínimo (Firebase Cloud Messaging API Admin); las API keys de `google-services.json` restringidas a la app (Cloud → Credentials); rotación (si se compromete) = clave nueva → `eas credentials` → subir → borrar la vieja.	Push de prueba (notify-dispatch dry → `canal`) llega a un Android real; una sola clave en la service account.
C21 · Firma de las apps: cert + perfil iOS (EAS, caducan 29-jul-2027) · keystore Android (EAS, generado 5-ago; SIN copia fuera de EAS)	HOY: «no hay fichero local que perder» = tampoco hay copia si Expo se pierde. QUÉ (D7, puede hacerse ANTES de noviembre porque no rota nada): `eas credentials` → Android → «Download credentials» → `secrets/android-keystore/` (600) → copia cifrada en R2 (backup-auto) → ficha en el gestor con la ruta y las contraseñas del keystore (que EAS muestra en ese menú); fechas a la tabla (`caduca_el` iOS 29-jul-2027; renovar en junio-2027 con `eas credentials`).	`keytool -list -keystore ...` (con la contraseña del gestor) enseña el alias; huella SHA-1 igual a la que muestra Play Console → App integrity; fechas en la tabla.

Qué	Hoy · qué se hará (paso a paso, en la semana previa a GA salvo que diga «ahora»)	Cómo se verificará
C22 · Credenciales del Mac que se re-crean con login (llavero): git HTTPS x3 repos + backup-auto · `supabase login` · `eas login` · `wrangler login` · rclone.conf	HOY: funcionan; no están inventariadas en sus servicios. QUÉ (verificar): cada servicio lista el token del Mac con nombre reconocible (GitHub → tokens; Supabase → Access Tokens; Expo → Access tokens; Cloudflare → API Tokens muestra el OAuth de wrangler); lo desconocido se borra; NADA de esto va al gestor (se rehace con login); `chmod 600` en rclone.conf y en todo `secrets/`.	`git push` (3 repos) · `npx supabase projects list` · `eas whoami` · `npx wrangler whoami` · `rclone lsd r2cifrado` — los cinco responden desde el Mac; `ls -l secrets/` todo -rw-----.
C23 · Higiene de `secrets/` (AHORA, no rota nada)	QUÉ: borrar `edge-functions.envecho` (hoy, junto a B3 solo se borra el fichero; la línea buena queda en env) — NO: por D0 se deja TODO como está hasta noviembre salvo el `.envecho`, que no es una rotación sino basura con un valor ya expuesto dentro → se borra ahora (`rm secrets/edge-functions.envecho`); `BUZONES-IONOS.md` → los 8 al gestor (A8); `WIFI-ROUTER.md` es personal (fuera de alcance, no se toca); `firma-juanjo.png` se queda (sensible: nunca a repos ni al hub); `README.md` → ~40 filas (0.2); `.copia` la sella backup-auto.	`ls secrets/` sin `.envecho`; README con las filas de este doc; `backup-estado` en verde en la línea de secrets.

4 · Análisis de impacto

Dónde	Qué toca	Qué NO toca
Cuentas de persona (A1-A13)	Verificación AHORA (2FA, recovery, miembros, inventario de tokens); rotación de Cloudflare/Outlook en noviembre (A2/A3).	Ningún código, ninguna OTA, ningún po: son paneles.
Supabase	Noviembre: contraseña del rol postgres (B2) · Vault (NS_CRON_SECRET, ns_feedback_token, NS_BACKUP_TOKEN, NS_OPS_PIN según D6) · Edge secrets (`secrets set --env-file`) · `secrets unset` FIGMA_TOKEN y USDA_API_KEY.	RLS, políticas, service_role (C1: no se rota sin motivo), anon key, tablas, RPCs, datos de usuarias.
Edge Functions (13)	Ninguna se reescribe; las que leen un secreto rotado lo reciben en la siguiente invocación (secretos de proyecto). food-lookup: un nombre de variable menos (C13) → redeploy de esa función.	Lógica de las 13; Deploy Edge solo para food-lookup (C13) y como VEREDICTO en vivo de las demás.
Cloudflare · Pages x2 · Actions	Si C4 se rota: NS_GATEWAY en 2 proyectos + Deploy Web2 + Deploy Web (po). C15: Roll del token + secreto de Actions. A2: contraseña, 2FA, backup codes, miembros, inventario de API Tokens.	DNS, Access, WAF, Turnstile (salvo «Rotate secret» si C5), zonas, laramagonzalez.com.
EAS / Expo / GitHub `nutrisync-app`	D7: descarga del keystore a secrets/ (sin rotar). D8: retirar `eas-update.yml` + EXPO_TOKEN (commit en appdev y espejo pwadev; borrar secreto y access token).	Runtimes, OTAs publicadas, builds en tienda, cert/perfil/keystore (se COPIAN, no se cambian).
Mac de Juanjo	`secrets/` (README ~40 filas, `.envecho` fuera, `db-url.txt` nuevo en noviembre, `tools.env` nuevo por D4, keystore copiado), llavero (inventario), rclone (B4: remoto nuevo), backup-auto (apunta al remoto nuevo).	Repos (salvo D8 y D4: el Deploy Edge lee `edge-functions.env`, sin cambios de código), .command de deploy (siguen igual).
Founders (Pilar, Lucía, Mapi)	Aceptar invitaciones (Cloudflare · GitHub · ASC · Play · Cloud · Expo) con SU 2FA; captura de «2-Step Verification: On» de su Gmail; Pilar duplica las fichas del gestor; simulacro #32.	Su trabajo diario en el hub y en la app: nada cambia a la vista (UST-17 sigue: PIN mensual + contraseña por dispositivo).

Coste 0 € salvo el gestor si se elige Bitwarden Families (47,88 \$/año). Tiempo estimado de la semana pre-GA: bloque A (verificar) ~3 h repartidas · B2/B3 ~1 h · B4 ~1 tarde + 30 días de doble copia (empieza el día 0) · C (verificar + lo que D6 rote) ~4 h. Radio de explosión mayor: B2 (si el `db-url.txt` nuevo se escribe mal, el backup de la base se para: se ve en el hub a las 4 h) y C3 (ventana de minutos con crons en 401: por eso a las :35).

5 · Decisiones (fila a fila — D0 ya decidida por Juanjo · D1-D10 carril técnico, Juanjo · Pilar y Lucía corroboran y ejecutan su parte de A12/A-invitaciones)

#	Propuesta	Alternativa	Decisión
D0	Ventana de ejecución: nada se rota antes de la semana previa a GA (noviembre); hasta entonces solo verificación e inventario. Excepción: compromiso real.	Rotar YA las tres expuestas (Cloudflare, BASE, FIGMA) y dejar el resto para noviembre.	DECIDIDO (Juanjo, 27-sep 13:4x, literal): «No, no vamos a rotar nada hasta que vayamos a produccion en Noviembre». Consecuencia: este documento es inventario + plan; hasta la semana previa a GA solo se VERIFICA (bloque A, C «verificar») y se recogen evidencias; las filas EXPUESTAS (B1-B3) siguen expuestas con riesgo aceptado hasta entonces; única excepción: compromiso REAL confirmado → se rota en el acto y se anota aquí.
D1	Checklist VIVO en la base (regla de oro): tabla `ops_credenciales` (una fila por credencial de este doc: sistema · nombre · vive_en · custodia · estado expuesta/ok/débil · expuesta_el · caduca_el · rotada_el · verificada_el · como_rotar · como_verificar · orden) + RPC `admin_credenciales_list()` / `admin_credencial_sello(id, accion, nota)` (is_admin_mfa) + una sección en <code>daily-ops</code> que la pinta con ✓ «verificada» / <code>□</code> «rotada» y avisa a 30 días de cada `caduca_el`. Sin pestaña nueva (evita los 4 sitios). Se construye en S20 tras esta firma (UST aparte pequeña o as-built de esta). Las capturas van a `ops_evidencia` (bucket privado + PIN), no al chat.	Este documento + las notas del item GA del tablero (más barato; envejece: la fecha de la membresía de Apple o del JWT de Apple no avisa a nadie).	
D2	Orden de la semana pre-GA: 0.1 gestor → 0.2 baseline/copia → A (identidades; A2 Cloudflare la primera) → B2 → B3 → B4 (arranca el día 0 por los 30 días) → C según D6 → verificación final (smoke · crons 24 h · backup 4 h · backup-estado · Insights). Regla «la vieja no se borra hasta que la nueva está verificada» salvo recovery codes y contraseñas de cuenta.	Por sistema (todo Cloudflare, luego todo Supabase...).	
D3	Gestor compartido: Contraseñas de Apple, grupo «NutriSync» (las tres con iPhone/Mac; gratis; notas viajan con la ficha) + Pilar duplica en su bóveda personal. Confirmar lo elegido en #28 antes de crear las fichas vacías (0.1).	Bitwarden Families (47,88 \$/año) si alguna está en Android/Windows.	
D4	Dos ficheros de env en secrets/: `edge-functions.env` SOLO con lo que las 13 funciones leen (el Deploy Edge lo sube entero) y `tools.env` para lo del Mac (FIGMA_TOKEN...); `secrets_unset` de lo que sobra en el servidor (FIGMA_TOKEN, USDA_API_KEY). La superficie de Edge es el fichero, no lo que usan las funciones.	Dejar un solo fichero (FIGMA_TOKEN sigue viviendo en Supabase sin que nadie lo use).	
D5	Cifrado: contraseña nueva CON sal (`password2`), remoto nuevo `r2salud` para lo sensible (secrets · feedback · inputs · base) con 30 días de doble copia antes de borrar el viejo; fichas 1-2 del gestor reescritas con la forma exacta; simulacro de restauración con las fichas nuevas. Lo pesado no sensible (releases, archive, design-packs) sigue en Time Machine/disco (no está en R2).	Misma forma, un remoto, sin sal (dejarlo como está: toda la protección de los datos de salud en una contraseña tecleada a mano).	

#	Propuesta	Alternativa	Decisión
D6	Rotación por higiene en noviembre de los secretos de máquina NUNCA expuestos: SÍ los que salen a terceros o cumplen 3+ meses en noviembre y cuestan minutos con verificación clara (NS CRON SECRET · SMTP_PASS · OPENAI_API_KEY · CF_API_TOKEN · CLOUDFLARE_API_TOKEN de Actions · QA_GRANJA_PASS · NS_OPS_PIN si viajó por chat) · NO service_role (radio = todo; solo con motivo), anon (pública), las dos claves ASC (no caducan; su rotación cuesta una tarde y ya cobró el 14-ago), NS_GATEWAY/TURNSTILE (26-sep, recién nacidos), Google OAuth/Firebase (solo si se comprometen).	Rotar TODO (incluido service_role y las claves ASC) — una semana entera y riesgo de romper crons/envíos sin motivo.	
D7	Keystore Android: descargar la copia de EAS a `secrets/android-keystore/` + R2 cifrado + ficha en el gestor — puede hacerse ANTES de noviembre (no rota nada; es una copia). Motivo: hoy la firma de la app de Play existe en un único proveedor.	Confiar en EAS como único custodio (si la cuenta de Expo se pierde, se pierde la capacidad de actualizar la app en Play para siempre).	
D8	`eas-update.yml` + EXPO_TOKEN: MEDIR runs en Actions; retirar el workflow (appdev + espejo) y el secreto/token. La única puerta de OTA es `tools/OTA NutriSync App.command` (backup-estado · jest · 7 runtimes · mensaje). Si algún día se quiere CI, nace con UST y con las mismas puertas.	Mantener el workflow y rotar el token (dos puertas de publicación, una sin guardas).	
D9	Evidencias: cada fila verificada/rotada deja sello en la tabla (D1) y, cuando sea una captura (2FA activa, miembro añadido), en `ops_evidencia` (privado + PIN). Nada en chat, nada en WhatsApp, nada en Notion (sin bloques).	Solo el sello, sin captura.	
D10	Segunda persona en TODAS las consolas (Pilar): Cloudflare Administrator · GitHub colaboradora/org · ASC Admin · Play Admin · Google Cloud Owner · Expo Admin · Supabase ya owner · IONOS suya. Es la única continuidad real (regla 11-ago: «antes que las contraseñas, los segundos factores»). Carril técnico/continuidad: Juanjo invita, Pilar acepta con su 2FA.	Compartir las contraseñas de Juanjo (no sirve: el segundo factor llega a su móvil).	

6 · Baseline, verificación y marcha atrás

Momento	Qué se comprueba
AHORA (sep-oct, sin rotar nada)	Bloque A completo (2FA, recovery, miembros, inventario de tokens en cada consola) · A12 (4 capturas de Gmail) · C1 (grep = 0) · C14 (permisos del token de web-stats leídos en el panel) · C16 (runs de eas-update medidos) · C19 (¿Secret Key de Apple? fecha) · C21/D7 (copia del keystore) · C23 (`envecho` fuera; README ~40 filas) · 0.1 (gestor con fichas vacías) · D1 construido en S20 y las filas cargadas.
Día 0 de la semana pre-GA (noviembre)	0.2: baseline.sh + backup-estado verde + `secrets/.copia` del día; valores viejos guardados en el gestor «(vieja)»; B4 arranca (remoto nuevo + sync) porque necesita 30 días de doble copia.
Durante (por fila)	Cada rotación: valor nuevo generado por el servicio o `openssl rand` → gestor/fichero → montado en TODOS los consumidores de la fila (columna «vive en») → la verificación de la fila en verde → sello «rotada» con fecha → SOLO entonces se borra/revoca la vieja. Si la verificación falla: se vuelve al valor viejo (que sigue en el gestor) y se anota.
Final (DoD de la UST)	Todas las filas con sello «verificada» y las B con «rotada» · `node tools/smoke-prod.mjs` · PRODUCCIÓN SANA · `cron.job_run_details` 24 h sin fallos · backup-auto 2 corridas OK · `backup-estado` verde · Security Insights de Cloudflare sin «Users without MFA» · `secrets/CLOUDFLARE-cuenta.md` y `edge-functions.env` sin ningún valor anterior a la semana · Pilar entra en las 7 consolas · simulacro #32 hecho con el remoto nuevo.

Momento	Qué se comprueba
Marcha atrás	Cuentas: la contraseña vieja sigue en el gestor hasta el sello (Cloudflare/Outlook: si el reset se atasca, el login por GitHub sigue funcionando). Secretos de máquina: el valor viejo se vuelve a poner en el mismo sitio (Vault/secrets set/Pages) y se redepoya si hacía falta; por eso la vieja no se revoca hasta verificar. B2: Supabase no deja «volver» a una contraseña: si el `db-url.txt` nuevo falla, se resetea OTRA vez (coste: un clic). B4: el remoto viejo no se toca hasta pasados 30 días; la marcha atrás es apuntar backup-auto al viejo.

7 · What to Test (Pilar y Lucía, cuando se ejecute en noviembre)

1. Nada cambia a la vista: el hub abre igual (PIN de Access una vez al mes por dispositivo + contraseña del hub una vez por dispositivo), StartUp Admin igual, la app igual; el digest de las 07:15 sigue llegando a founders@.
2. Cada una recibe invitaciones (Cloudflare, GitHub, ASC, Play, Google Cloud, Expo) y las acepta con SU cuenta y SU 2FA; después comprueba que entra en cada consola sin pedirle nada a Juanjo.
3. En el gestor compartido ven el grupo «NutriSync» con una ficha por credencial (nombre, dónde vive, cómo se recupera) y Pilar tiene las fichas 1-2 duplicadas en su bóveda; Pilar hace el simulacro #32 (recuperar un fichero de R2 sola, con el remoto nuevo).
4. Cada una manda la captura «2-Step Verification: On» de su Gmail (es el segundo factor del hub) — sin ella, la fila A12 no se cierra.

8 · Lecciones grabadas (van también a CLAUDE.md)

Lección	Qué cambia
El mapa de secretos se MIDE en el código, no se recuerda	secrets/README.md tenía 13 filas y el grep de `Deno.env.get` · `vault.create_secret` · `secrets.*` de los workflows · `env.*` de las Pages Functions da ~40: faltaban CF_API_TOKEN (un token de Cloudflare viviendo en Supabase), NS_BACKUP_TOKEN, NS_OPS_PIN, QA_GRANJA_PASS, TURNSTILE/NS_GATEWAY, EXPO_TOKEN y CLOUDFLARE_API_TOKEN de Actions, y la doble USDA. Regla: el inventario se regenera con esos greps (script `tools/secretos-inventario.mjs`, solo NOMBRES) y el README/la tabla se comparan con él en cada baseline.
La superficie de Edge es el FICHERO, no lo que usan las funciones	El Deploy Edge sube `edge-functions.env` entero con `--env-file`: FIGMA_TOKEN (que ninguna función lee) vive en el servidor de Supabase, y tres líneas repetidas + un `envecho` accidental muestran que las rotaciones con `echo >>` dejan las viejas arriba. Cura: dos ficheros (Edge vs Mac, D4) y `secrets unset` de lo que sobra; rotar = REEMPLAZAR la línea, nunca añadir.
Un workflow olvidado es una puerta de publicación sin guardas	`eas-update.yml` (plantilla del arranque) publica una OTA en cada push a main si EXPO_TOKEN existe: fuera de backup-estado, jest y la lista RUNTIMES. No consta en CLAUDE.md ni en el OTA .command. Regla: todo `.github/workflows/*` de los 3 repos se lista en el baseline y cada uno tiene dueño y motivo, o se retira (D8).
«No hay fichero que perder» también significa «no hay copia»	El keystore de Android solo existe en EAS; la lección del 5-ago lo contaba como ventaja. Lo es contra la pérdida del Mac, no contra la pérdida de la cuenta de Expo. Toda credencial que custodie un proveedor y no se pueda regenerar (keystore, .p8 descargados una vez) tiene copia cifrada en R2 y ficha en el gestor (D7).
Verificar no es rotar, y la decisión del dueño manda	Juanjo: «no vamos a rotar nada hasta noviembre». Se acepta el riesgo de las tres expuestas hasta GA y se escribe (D0): lo que sí se hace ahora es lo que no cambia ningún valor (2FA, miembros, inventario, copias, evidencias). Un asistente que «aprovecha» para rotar algo pequeño fuera de la ventana está rompiendo la regla, no ayudando.

9 · La cadena

Paso	Estado
UST	Este documento (propuesta, 27-sep 13:4x): inventario medido (~40 filas) + plan por fila + D0 ya decidido.
Sign-off	Juanjo valida D1-D10 fila a fila (carril técnico). Pilar y Lucía corroboran, aceptan invitaciones y hacen A12 y el simulacro (no bloquea).
Dev	S20: D1 (tabla `ops_credenciales` + 2 RPC + sección en daily-ops + carga de las filas de este doc) · `tools/secretos-inventario.mjs` (solo nombres) · D4 (dos env) · D8 (retirar workflow) · D7 (copia del keystore, en el Mac). Todo lo demás son paneles en noviembre.

Paso	Estado
Test	arnés PG16 para el SQL de D1 (RPC gated, sello idempotente); web-tests (contrato RPC↔SQL, hub r17-g sobre daily-ops); admin-tests sin cambios.
Deployment	po (daily-ops) + SQL en la bandeja + Deploy Edge food-lookup (C13) cuando toque; noviembre: rotaciones por fila según D2.
Verification	AHORA: bloque A + C-verificar sellados; NOVIEMBRE: DoD del apartado de verificación (smoke · crons · backup · Insights · Pilar en 7 consolas).
hub + Notion	Hub: este doc 56 + adjunto; tablero: item GA «Rotar antes de producción» (ya escrito, apunta aquí) + item S20 «Readiness vivo (D1)» + item «retirar eas-update.yml (D8)» + item «copia del keystore (D7)». Notion: sin bloques → hub.

Firmas

Persona	Rol	Conforme	Fecha
Juanjo Cebrián	Ingeniería y producto (D0 decidido · D1-D10 carril técnico; ejecuta rotaciones e invitaciones)		
Pilar González	CEO · cumplimiento (corroborar; acepta invitaciones con su 2FA; duplica fichas; simulacro #32; A12)		
Lucía Cebrián	COO · diseño (corroborar; acepta invitaciones; A12)		